AES est une permutation : *de quoi parle-t-on ?*

Ensemble et correspondance, fonction, arrangement et permutation, la clé comme numéro de catalogue

Introduction à la cryptographie moderne
Benoit LEGER-DERVILLE · Stelau · iDAKTO

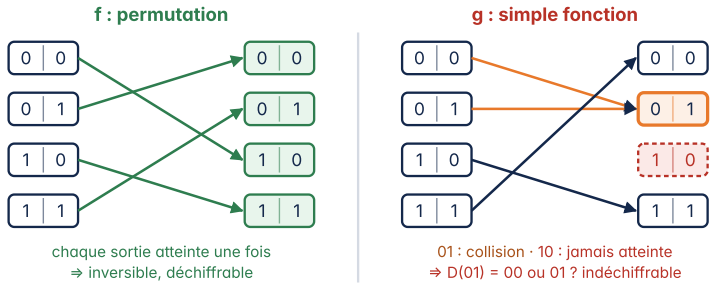
1 L'ensemble ne change jamais : c'est la correspondance qui compte

Un chiffrement par bloc prend un bloc dans l'ensemble de **tous** les blocs possibles et rend un bloc du **même** ensemble : 2^{128} valeurs pour AES, il n'y en a pas d'autres. La question n'est donc pas « quels blocs existent ? » mais **« comment chaque entrée est-elle associée à une sortie ? »**

Exemple jouet avec des blocs de **2 bits**, écrits comme AES écrit ses 16 octets : une case par élément. Soit 4 valeurs, et deux correspondances sur le même ensemble :

- **f est une permutation** (bijection) : chaque sortie est atteinte **exactement une fois**. On peut remonter les flèches : f est inversible.
- **g est une simple fonction** : 00 et 01 tombent sur 01 (**collision**), et 10 n'est jamais atteinte. Si g chiffrait, que donnerait le déchiffrement de 01 ?

Une fonction de hachage est de ce second type : elle a infiniment plus d'entrées que de sorties, elle ne peut pas être inversible.



Mot	Sens précis	Où on le rencontre
Fonction, correspondance	Chaque entrée a **une** image ; deux entrées peuvent avoir la même (collision).	Hachage, KDF. **Impossible** pour un chiffrement : pas de déchiffrement.
Arrangement	Suite ordonnée de k éléments **distincts** pris parmi N : N! / (N − k)! possibilités.	Le flux CTR E_K(1), ..., E_K(q) est un arrangement de q blocs (section 13).
Permutation, bijection	Arrangement de **tous** les N éléments (k = N) : chaque élément atteint une fois. N! possibilités.	AES_K, pour chaque clé K. Tout chiffrement par bloc (section 3).
Renumérotation	La même chose vue comme une table : chaque bloc reçoit un nouveau numéro, tous différents.	La table de 2^{128} lignes d'AES_K, que personne n'écrit jamais (2^{132} octets).
Réarrangement des positions	Déplacer les éléments **d'une** suite sans les changer.	ShiftRows, une étape d'un tour d'AES (section 5). Pas AES lui-même.

2 Combien de correspondances possibles ?

Bloc	Valeurs N	Fonctions N^N	Permutations N!	Clés
2 bits	4	256	24	—
3 bits	8	16 777 216	40 320	8 (section 15)
8 bits	256	2^{2048}	$\approx 2^{1684}$	1 : la S-box
128 bits	2^{128}	$2^{(128 \cdot 2^{128})}$	$\approx 2^{(126{,}6 \cdot 2^{128})}$	2^{128} ou 2^{256}

Avec Stirling, $(2^{128})! \approx 2^{(2^{135})}$: **écrire le seul numéro** d'une permutation demanderait $\approx 2^{135}$ bits, plus que toute la mémoire du monde. Une clé AES-128 en a 128. Elle ne peut donc désigner que 2^{128} permutations, une fraction infinitésimale.

Tout le pari d'AES : que cette minuscule famille, choisie avec une clé secrète, **ressemble** à une permutation tirée au hasard parmi toutes (section 12).

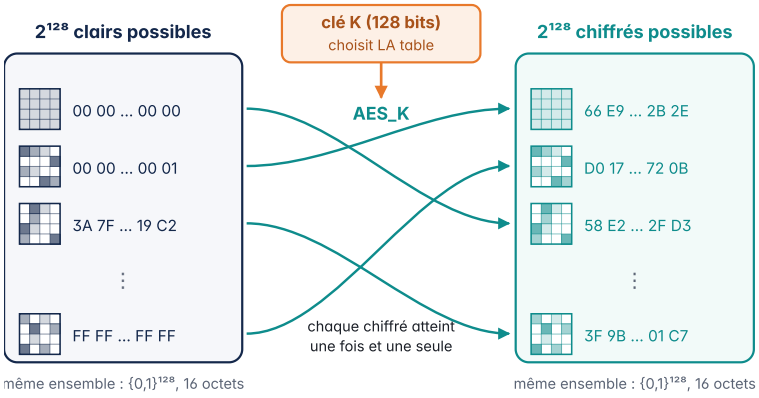
3 Pourquoi tout chiffrement par bloc est une permutation

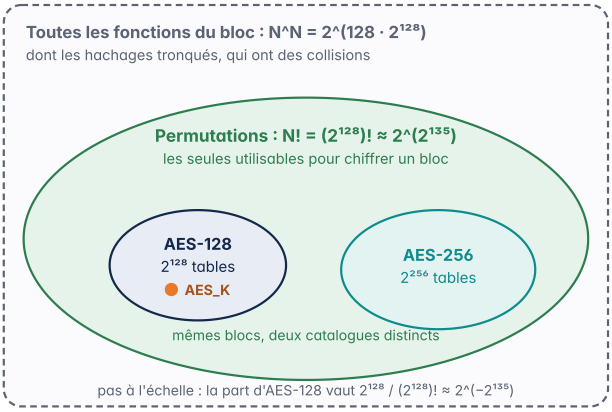
```
déchiffrer ⇒ E_K injective
(deux clairs ≠ ⇒ deux chiffrés ≠)
injective + |entrées| = |sorties| = 2^128
⇒ surjective (principe des tiroirs)
⇒ E_K bijective : une permutation
```

Ce n'est pas un choix de conception mais une **obligation** : un chiffrement par bloc qui ne serait pas une permutation ne pourrait pas être déchiffré. DES, 3DES, AES, et même le masque jetable à clé fixée (section 10) sont des permutations.

À l'inverse, un hachage (entrées de toute taille, 2^{256} sorties pour SHA-256) a forcément des collisions : on lui demande seulement qu'elles soient **introuvables**.

4 Une clé, une permutation, choisie dans un catalogue minuscule





Bloc et clé : deux tailles qui n'ont rien à voir. Le bloc (16 octets) fixe *ce qu'on mélange* : toujours 2^{128} valeurs, pour AES-128, -192 et -256. La clé fixe *combien de mélanges* on peut désigner : 2^{128}, 2^{192} ou 2^{256}. Que les deux valent 128 dans AES-128 est une coïncidence.

La clé n'est pas mélangée au message comme dans le masque jetable : elle est le **numéro de catalogue** de la table de renumérotation. AES calcule à la demande la ligne utile de cette table, en 10 tours, sans jamais la stocker.

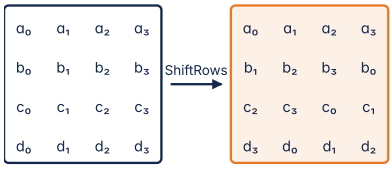
Aucun bloc n'est privilégié. Chaque table atteint les 2^{128} chiffrés : le bloc qui porte 72 en 8e position et `0B` en dernière existe pour toutes les clés. Un éventuel « signe de reconnaissance » ne peut se loger ailleurs que dans les relations entre blocs (section 7).

Dans AES : *quatre bijections, aucun marquage*

Deux sens de « permutation », anatomie d'un tour, pourquoi les 2^{128} tables d'AES ne se repèrent pas

5 Deux sens du mot « permutation », à ne pas confondre

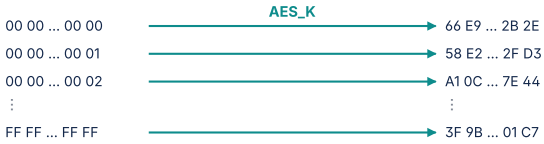
Réarranger les 16 octets d'UN bloc



Mêmes octets, autres places.
16! ≈ 2^{44} façons possibles.
C'est ShiftRows : une seule étape d'un tour, et non AES lui-même.

Un tel « chiffrement » laisse voir tous les octets du clair.

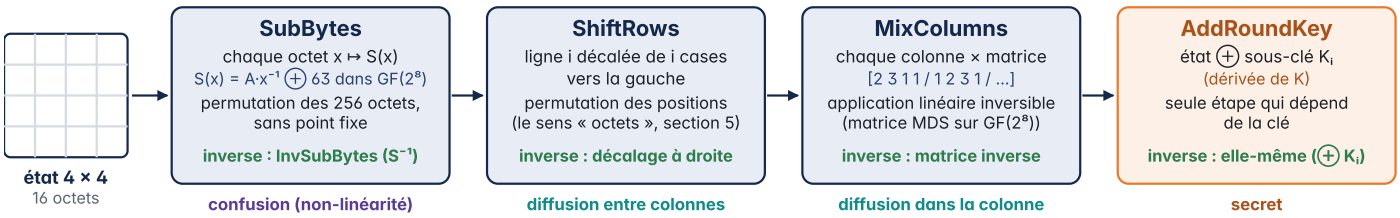
Renuméroter TOUS les blocs possibles



(2^{128})! façons. Chaque bloc devient un autre bloc, avec des octets qu'il ne contenait pas : on ne déplace pas, on **renumérote**.

Vecteur de test réel : AES-128, clé nulle, bloc nul ⇒ `66 E9 4B D4 EF 8A 2C 3B 88 4C FA 59 CA 34 2B 2E`. Les autres lignes sont illustratives.

6 Anatomie d'un tour d'AES : quatre bijections



10, 12 ou 14 tours selon la clé (128, 192, 256 bits) ; dernier tour sans MixColumns. **Composition de bijections = bijection** : D_K applique les inverses dans l'ordre inverse.

Confusion et diffusion (Shannon, 1949) : la S-box rend la relation clé–chiffré non linéaire ; ShiftRows et MixColumns font dépendre chaque bit de sortie de **tous** les bits d'entrée dès 2 tours (effet avalanche : un bit changé en entrée inverse chaque bit de sortie avec une probabilité ≈ ½). L'architecture est un **réseau de substitution-permutation** (SPN), où « permutation » désigne justement ShiftRows. DES, lui, est un **schéma de Feistel**, inversible même si sa fonction interne ne l'est pas.

La S-box, une permutation que l'on peut lire : une table de 256 octets dans laquelle chaque valeur de 00 à FF apparaît **exactement une fois**. Extraits : `S(00) = 63` · `S(01) = 7C` · `S(02) = 77` · `S(53) = ED` · `S(FF) = 16`, et S^{-1}`(63) = 00`. Aucun octet n'est envoyé sur lui-même ni sur son complément. C'est la seule pièce non linéaire d'AES, et elle est publique : **le secret est uniquement dans les sous-clés** (principe de Kerckhoffs).

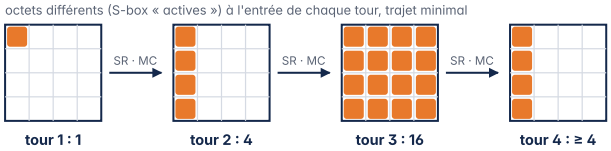
7 Aucun chiffré interdit : où se cacherait un « marquage » ?

Sur un bloc isolé, rien à voir. Pour une clé fixée, AES_K atteint les 2^{128} chiffrés (section 4). À clair P_0 fixé et clé variable, K ↦ AES_K(P_0) se comporte comme une fonction aléatoire : elle atteint ≈ 1 − 1/e ≈ **63 %** des blocs, sans position ni valeur d'octet privilégiée.

Un signe de reconnaissance des 2^{128} tables ne peut donc se lire que dans des **relations** : entre deux clairs et leurs chiffrés, entre des bits du clair, du chiffré et de la clé, ou entre les tables elles-mêmes. Quatre familles d'attaques cherchent ces relations ; AES a été conçu contre chacune.

Marquage	Ce qu'il serait	Ce qu'AES y oppose
Différentiel	Un écart $\Delta P = P_1 \oplus P_2$ favorise (ou interdit) un écart ΔC.	S-box : probabilité ≤ 2^{-6} ; ≥ 25 S-box actives en 4 tours ⇒ ≤ 2^{-150} (section 8).
Linéaire	Un XOR de bits de P, C et K vrai avec une probabilité ½ + ε.	S-box : corrélation ≤ 2^{-3} ; 25 boîtes ⇒ ≤ 2^{-75}, soit ≈ 2^{150} couples à observer.
Algébrique	Des équations de bas degré relient P, C et K.	Inversion dans GF(2^8) : degré 7 par S-box, qui s'accumule de tour en tour.
Structurel	$AES_K_2 \circ AES_K_1 = AES_K_3$: le catalogue serait un petit groupe.	Les tours engendrent tout le groupe alterné (Wernsdorf 2002) : on sort du catalogue (section 15).

8 La stratégie de la « piste large » (*wide trail*) et ses limites



au moins 1 + 4 + 16 + 4 = 25 S-box actives sur 4 tours

MixColumns est MDS (nombre de branchement 5) : si une colonne diffère sur 1 octet en entrée, elle diffère sur ses 4 octets en sortie, et en tout au moins 5 octets diffèrent entre entrée et sortie. ShiftRows envoie ensuite les 4 octets d'une colonne dans 4 colonnes différentes. Conséquence prouvée : **toute** trajectoire sur 4 tours traverse au moins 25 S-box actives.

La rigidité a un revers : sur 4 tours, certains motifs d'écart ont une probabilité **exactement nulle** (deux clairs différant d'un octet ne donnent jamais certaines colonnes égales). Ces **différentielles impossibles** servent à attaquer AES-128 réduit jusqu'à 7 tours. À 10 tours, chaque motif de sortie est alimenté par un nombre astronomique de chemins : la marge est de 3 tours.

Est-on certain qu'aucun marquage n'existe ? Non, et personne ne le prétend. Il n'existe aucune preuve qu'AES soit une PRP (en prouver une pour des familles de ce type impliquerait au moins P ≠ NP). La confiance repose sur des **bornes prouvées** contre les familles d'attaques connues et sur **25 ans de cryptanalyse publique** : la meilleure attaque contre AES-128 complet (biclique, Bogdanov, Khovratovich, Rechberger 2011) coûte encore ≈ 2^{126} opérations, un gain d'un facteur 4 sur la force brute.

Références : FIPS 197 · Daemen, Rijmen 2002 (wide trail) · Wernsdorf, FSE 2002 · Biham, Keller 1999 (différentielles impossibles) · Bogdanov et al., ASIACRYPT 2011

128 bits de clé, *un téraoctet de données*

Primitive et mode, masque jetable et AES-CTR, sécurité parfaite et sécurité calculatoire, jeu PRP

9 Primitive et mode : qui fait quoi pour chiffrer 1 To ?

Ingrédient	Taille	Rôle
Bloc	128 bits, fixe	**Ce qu'on mélange** : AES ne sait traiter que 16 octets à la fois.
Clé	128, 192, 256 bits	**Quelle table** on utilise (section 4).
Mode + nonce	nonce 96 bits	**Comment on enchaîne** les 2^{36} blocs d'un Tio, sans répéter le même dictionnaire.

- **ECB** : $C_i = E_K(P_i)$. Un seul dictionnaire pour tout le fichier : deux blocs clairs égaux (silence audio, pixels blancs, zéros) donnent deux chiffrés égaux. Proscrit.
- **CBC** : $C_i = E_K(P_i \oplus C_{i-1})$. Deux clairs égaux arrivent devant AES avec des valeurs différentes.
- **CTR** (et GCM) : $S_i = E_K(N \parallel i)$, puis $C_i = P_i \oplus S_i$. Le message ne passe même plus dans AES : la permutation **fabrique un masque** de 1 To qui imite le masque jetable.

Masque jetable : la clé EST le flux



1 To d'aléa, blocs tirés **avec remise** :
deux K_i égaux sont possibles, par hasard

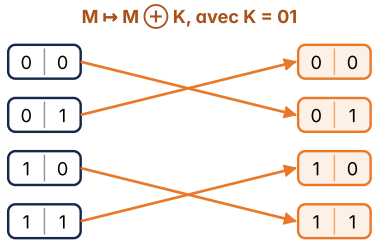
AES-CTR : la clé (16 o) fabrique le flux



compteurs tous distincts + permutation ⇒ blocs
tirés **sans remise** : jamais deux égaux (section 13)

1 Tio = 2^{40} o = **2^{36} blocs**, tous issus des mêmes 128 bits

10 Le masque jetable est, lui aussi, une permutation



Pour une clé K fixée, $M \mapsto M \oplus K$ atteint chaque sortie une fois : c'est une **permutation**, et même sa propre inverse. Ce qui distingue le masque jetable d'AES n'est donc pas « permutation ou non », mais **le genre de permutation et l'usage de la clé**.

- **Permutation triviale** : un seul couple (M, C) connu révèle la clé, $K = M \oplus C$.
- **Sans conséquence**, car K ne sert qu'une fois : K uniforme ⇒ chaque C est également probable quel que soit M. C'est la **sécurité parfaite** de Shannon (1949) : $H(M \mid C) = H(M)$.
- **Réutiliser K** : $C_1 \oplus C_2 = M_1 \oplus M_2$, la clé s'annule (projet Venona). Même piège que le nonce réutilisé en CTR et GCM.

Pour chiffrer 1 Tio (2^{43} bits)	Masque jetable	AES-128 en mode CTR
Clé	2^{43} bits d'aléa, à transmettre et détruire	128 bits
Chiffrés possibles pour un clair donné	tous : 2^(2^{43}), équiprobables	2^{128} seulement (un par clé, nonce fixé)
Attaquant à puissance infinie	n'apprend **rien** : toutes les clés donnent un clair plausible	essaie les 2^{128} clés : **une seule** donne un fichier cohérent
Couples (M, C) tolérés par clé	**aucun** au-delà du message lui-même	des milliards, sans fuite de K
Nature de la sécurité	parfaite, inconditionnelle	calculatoire : 2^{128} opérations hors de portée

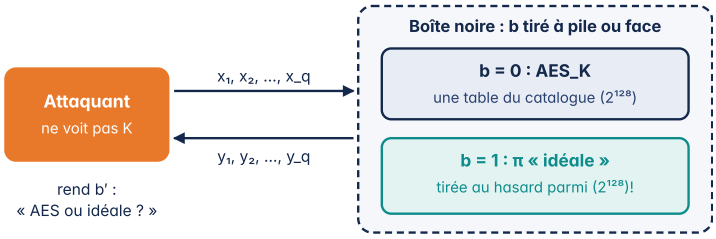
11 Où est passée l'incertitude ?

Avec le masque jetable, l'incertitude sur le clair reste de **1 To** après interception. Avec AES, elle ne peut jamais dépasser **128 bits**, ceux de la clé : le chiffré d'un téraoctet est immensément redondant.

Shannon appelle **distance d'unicité** la longueur de chiffré au-delà de laquelle une seule clé reste compatible. Pour un texte en français (≈ 6 bits de redondance par octet), elle vaut 128 / 6 ≈ **22 octets** : moins de deux blocs. Le reste du téraoctet n'ajoute aucun secret.

> Toute la sécurité d'AES tient donc à une hypothèse : la redondance est là, mais **verrouillée derrière un calcul** que personne ne sait faire. Tester 2^{128} clés à 10^{18} essais par seconde prendrait ≈ 10^{13} ans, près de 800 fois l'âge de l'Univers.

12 Le jeu PRP : ce que veut dire « pseudo-aléatoire »



AES est une PRP (*pseudo-random permutation*) si aucun attaquant réaliste ne devine b nettement mieux qu'au hasard, même avec un très grand nombre q de requêtes : le catalogue est **indiscernable** de l'ensemble de toutes les permutations.

> **Le XOR échoue en deux requêtes** : avec $M \mapsto M \oplus K$, on a toujours $y_1 \oplus y_2 = x_1 \oplus x_2$, ce qu'une permutation idéale ne vérifie presque jamais. D'où l'impossibilité de réutiliser la clé du masque jetable.

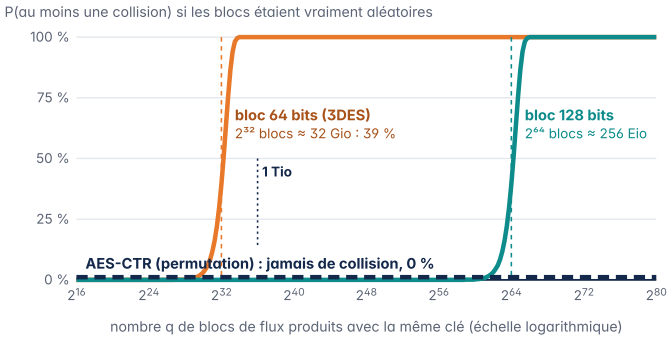
Anniversaires et *catalogue en miniature*

Où une permutation se trahit, combien de données par clé, et toute la théorie sur 3 bits

Introduction à la cryptographie moderne
Benoit LEGER-DERVILLE · Stelau · iDAKTO

13 Permutation ou aléa pur : la trace des anniversaires

Le masque jetable tire ses blocs **avec remise** : un bloc se répète par hasard dès ≈ 2^(n/2) blocs (**paradoxe des anniversaires**). AES-CTR applique une permutation à des compteurs tous différents : un tirage **sans remise**, jamais de répétition. Le flux d'AES est « trop parfait » : c'est sa seule signature inévitable.




```
P(collision) ≈ 1 - exp(-q² / 2^(n+1)) · 39 % à q = 2^(n/2)
Avantage PRP/PRF ≤ q² / 2^(n+1)  (lemme de commutation)
```

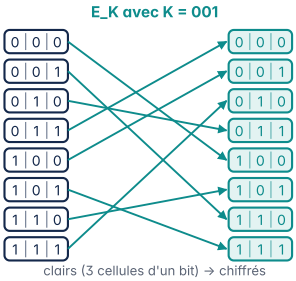
14 Combien de données par clé ?

Volume	q	avantage	Ce que cela veut dire
16 Mio	2^{20}	2^{-89}	Indétectable.
1 Tio	2^{36}	2^{-57}	Il faudrait ≈ 2^{57} téraoctets indépendants pour voir la différence.
4 Pio	2^{48}	2^{-33}	Ordre de grandeur des limites par clé recommandées.
256 Eio	2^{64}	≈ ½	Borne des anniversaires : l'absence de collision trahit la permutation.

Bloc de 128 bits, avantage ≤ $q^2 / 2^{129}$. La limite dépend de la **taille du bloc**, pas de la clé : elle est la même pour AES-256.

Cas	Ce qui se passe
Bloc de 64 bits (DES, 3DES, Blowfish)	Seuil à 2^{32} blocs = 32 Gio. **Sweet32** (Bhargavan, Leurent 2016) : en CBC, deux chiffrés égaux $C_i = C_j$ donnent $P_i \oplus P_j = C_{i-1} \oplus C_{j-1}$; un cookie HTTPS récupéré. 3DES retiré.
Nonces GCM aléatoires de 96 bits	Même calcul sur les nonces : SP 800-38D limite à **2^{32} messages par clé** pour un risque de répétition ≤ 2^{-32}.

15 Toute la théorie sur 3 bits : 8 clés, 8 permutations parmi 40 320



Chiffrement jouet sur des blocs de **3 bits** avec une clé de **3 bits** : E_K(x) = S(x ⊕ K), où S est une petite S-box fixe et publique (S = 110 100 000 011 111 001 010 101 pour x = 000 ... 111). Chaque ligne est la table d'une clé ; chaque ligne contient les 8 valeurs une fois : ce sont 8 permutations, toutes différentes.

x →	000	001	010	011	100	101	110	111
K = 000	110	100	000	011	111	001	010	101
K = 001	100	110	011	000	001	111	101	010
K = 010	000	011	110	100	010	101	111	001
K = 011	011	000	100	110	101	010	001	111
K = 100	111	001	010	101	110	100	000	011
K = 101	001	111	101	010	100	110	011	000
K = 110	010	101	111	001	000	011	110	100
K = 111	101	010	001	111	011	000	100	110
π hors catalogue	011	000	110	101	001	111	100	010

8 clés = tables du catalogue

40 320 permutations : 8!

16,8 M fonctions : 8^8

Le catalogue couvre **8 / 40 320 ≈ 0,02 %** des permutations. La ligne rouge π est une permutation parfaitement valable (chaque valeur une fois), mais **aucune clé ne la donne** : elle est hors catalogue, comme l'immense majorité des $(2^{128})!$ tables pour AES.

Pas de petit groupe : en enchaînant deux clés ($E_K_2 \circ E_K_1$), on obtient 64 permutations dont **aucune** n'est dans le catalogue. Un attaquant de ce jouet le casse évidemment : 8 clés à essayer, et une seule paire (x, y) connue suffit à désigner la clé (les 8 clés envoient x sur 8 valeurs différentes). Pour AES, il faudrait en essayer 2^{128}.

À retenir

- **Permutation** = correspondance où chaque sortie est atteinte une fois, sur l'ensemble de **tous** les blocs. Tout chiffrement par bloc en est une, par obligation.
- **La clé choisit une table** dans un catalogue de 2^{128} (ou 2^{256}), perdu parmi $(2^{128})!$; **le mode** l'enchaîne pour chiffrer des téraoctets.
- **Pseudo-aléatoire** = indiscernable d'une table tirée au hasard. Seule trace inévitable : l'absence de collisions, d'où une limite de volume par clé fixée par la taille du bloc.

16 Expérience de cours : les anniversaires en petit

23 élèves suffisent pour une chance sur deux d'anniversaires communs (seuil ≈ √365). Sur des blocs de 8 bits, un tirage aléatoire répète un octet après ≈ 20 tirages (√(π·256/2)) ; une permutation, jamais avant 256.

```
import random
N = 256
perm = random.sample(range(N), N)                # permutation
func = [random.randrange(N) for _ in range(N)]   # fonction
def premiere_collision(suite):
    vus = set()
    for i, y in enumerate(suite):
        if y in vus: return i
        vus.add(y)
print(premiere_collision(perm))  # None
print(premiere_collision(func))  # ≈ 20
```